CompTIA CySA+ Instructor Guide: Step-by-Step Log Analysis

Based on your uploaded CySA+ Real-World Log Analysis Lab (21 scenarios)

This instructor guide is designed for live classroom delivery. Each scenario will teach students how to read the actual log, understand what each important field means, identify suspicious behavior, and select the correct threat assessment.

For each log, the instructional sequence is:

1. Introduce the scenario: Explain what system generated the log and why an analyst would investigate it.
2. Read the log step by step: Break down the timestamp, source, destination, processes, commands, event IDs, and other relevant fields.
3. Connect the evidence: Explain what the individual fields reveal when analyzed together.
4. Identify the threat: Explain the lab's correct answer and what the evidence does—and does not—prove.
5. Discuss the analyst response: Explain what a security analyst should investigate next.
6. CompTIA CySA+ exam takeaway: Reinforce the indicators students should recognize on the certification exam.

An important distinction for students: Suspicious activity is not always confirmed malicious activity. A good analyst distinguishes what the log directly proves from what additional investigation is needed to establish.

Recommended instructor demonstration

For each scenario, have students identify the source system and the single most important indicator before showing the lab's analyst hint. Then reveal the supporting fields, explain the intended answer, and discuss what additional evidence would be required in a real SOC investigation.

I would emphasize five recurring questions during delivery:

1. Who initiated the activity? Identify the account, process, hostname, or source IP.
2. What action occurred? Identify the command, connection, authentication, file operation, or configuration change.

3. What makes it suspicious? Compare it with expected system behavior.
4. What can we actually prove? Separate observed facts from suspected attack techniques.
5. What should the analyst investigate next? Identify corroborating logs, artifacts, and appropriate response actions.

Important corrections to highlight during instruction

A few of the lab's explanations are more definitive than the evidence supports. In particular, AppLocker Event ID 8002 should not be taught as a blocked execution event; Sysmon Event ID 11 does not by itself prove mass file encryption; Auditd openat does not alone prove file contents changed; and suspicious network activity does not automatically confirm command-and-control or data exfiltration.

These distinctions are especially valuable for CySA+ students because the exam tests their ability to interpret evidence, not simply memorize suspicious keywords.

Final CySA+ exam takeaway: The strongest security assessments connect multiple indicators. A process name, port number, event ID, or unusual IP address can raise suspicion, but the surrounding context determines whether it represents normal administration, a policy violation, or an actual security incident.

Part 1 — Network Security Logs

Log 1 — Palo Alto NGFW Flow Telemetry

Ticket: INC-8102 | Correct answer: Bandwidth Consumption

Step 1: Identify the log source. This is a Palo Alto Networks firewall traffic log. It records which systems communicate, what protocol and port they use, whether traffic is allowed, and how much data transfers.

Step 2: Read the traffic record.

Src_IP: 10.0.0.25

Dst_IP: 198.51.100.50

Dst_Port: 443

Protocol: tcp

Action: allow

Bytes_Sent: 128848000000

Bytes_Recv: 1018880

Explain the fields to students:

- 10.0.0.25 is the internal server initiating the connection.
- 198.51.100.50 represents the external destination.
- 443/tcp commonly carries HTTPS traffic.
- allow means the firewall permitted the traffic.
- Bytes_Sent shows approximately 128.85 GB transmitted.
- Bytes_Recv shows approximately 1.02 MB received.

Step 3: Explain what is happening. The internal server transmitted an unusually large amount of information outward while receiving very little in return. This asymmetric traffic pattern can indicate heavy outbound bandwidth consumption and potentially data exfiltration.

Step 4: Identify the answer. Bandwidth Consumption is the lab's answer because the outstanding indicator is the enormous outbound byte count. The log does not provide a session duration or link capacity, so it cannot independently prove bandwidth saturation.

Step 5: Analyst response. Verify the destination, session duration, baseline transfer volume, approved business purpose, and whether sensitive files were accessed.

Instructor takeaway: Teach students to compare Bytes_Sent against Bytes_Recv. Large outbound transfers are important indicators, but volume alone does not prove an attack.

Log 2 — Zeek/Bro Connection Telemetry

Ticket: INC-2910 | Correct answer: Beaconing

Step 1: Identify the source. Zeek is a network security monitoring platform. Its conn.log records connection metadata such as source, destination, ports, timestamps, duration, and transferred bytes.

Step 2: Examine the timestamps.

09:00:00 → 192.168.1.101 → 104.27.142.32:443

09:05:00 → 192.168.1.101 → 104.27.142.32:443

09:10:00 → 192.168.1.101 → 104.27.142.32:443

09:15:00 → 192.168.1.101 → 104.27.142.32:443

All four connections use TCP port 443, last approximately three seconds, and record 124 original bytes and 412 response bytes.

Step 3: Identify the pattern. The workstation initiates connections at exactly five-minute intervals. The source port changes, but the destination, timing, and application payload byte counts remain consistent.

Step 4: Explain the security concern. Malware frequently uses periodic outbound communications to contact command-and-control (C2) infrastructure. These check-ins are called beacons. The same pattern can also occur in legitimate monitoring software, so corroboration is necessary.

Step 5: Analyst response. Investigate the process responsible for the connections, destination reputation, DNS history, and whether the behavior is authorized.

Instructor takeaway: Regular connection intervals + repeated destination + similar data sizes = potential C2 beaconing.

Log 3 — Windows Sysmon Event ID 3

Ticket: INC-3912 | Correct answer: Irregular Peer-to-Peer Communication

Step 1: Identify the event. Sysmon Event ID 3 records a network connection associated with a process, when network connection logging is enabled.

Step 2: Break down the important fields.

Computer: WKST-DEPT32.corp.internal

ProcessId: 4102

Image: C:\Windows\System32\cmd.exe

User: CORP\jdoe

Initiated: true

SourceIp: 10.0.3.12

DestinationIp: 10.0.3.15

DestinationPort: 445

Explain that Image identifies the process associated with the connection, User identifies its account context, and Initiated=true indicates that the local host initiated it.

Step 3: Explain port 445. TCP 445 is commonly used for SMB, which supports Windows file sharing and other network functions.

Step 4: Explain the behavior. One workstation initiated SMB communication directly to another workstation, rather than to a dedicated file server. This may be normal in some environments but suspicious in networks that prohibit workstation-to-workstation SMB access.

Step 5: Analyst response. Check segmentation policy, SMB authentication events, accessed shares, and whether the account was authorized to access the target.

Instructor takeaway: Direct SMB connections between workstations can indicate lateral movement. Relevant ATT&CK technique: T1021.002, SMB/Windows Admin Shares, when the associated remote-service behavior is established.

Log 4 — Cisco Wireless LAN Controller

Ticket: INC-4021 | Correct answer: Rogue Devices on Network

Step 1: Identify the alert.

%WLAN-4-ROGUE_AP_DETECTED

This identifies a Cisco wireless alert with a warning-level severity designation.

Step 2: Break down the wireless evidence.

Reporting AP: AP-ConfRoomB

Rogue BSSID: 00:11:22:33:44:55

Channel: 6

RSSI: -48 dBm

SNR: 42

SSID: Free_Corp_WiFi

Auth: None

Encryption: None

Explain that a BSSID identifies a wireless radio interface, the SSID is the advertised wireless network name, RSSI represents received signal strength, and SNR measures signal relative to noise.

Step 3: Explain what happened. A managed access point detected another wireless transmitter advertising an apparently corporate-related network without authentication or encryption.

Step 4: Explain the threat. This may represent an unauthorized access point or an evil-twin attempt intended to lure users into connecting.

Step 5: Analyst response. Verify whether the BSSID is approved, locate the device, examine associated clients, and determine whether the SSID is impersonating a trusted network.

Instructor takeaway: Rogue AP detection identifies suspicious wireless infrastructure; an evil-twin attack requires evidence of impersonation or deceptive intent.

Log 5 — Nginx Web Server Access Log

Ticket: INC-5182 | Correct answer: Scans/Sweeps

Step 1: Identify the source. Nginx access logs record HTTP requests made to a web server.

Step 2: Review the requested resources.

GET /phpmyadmin/ 404

GET /admin/ 404

GET /wp-login.php 404

GET /.env 404

GET /config.json 404

GET /api/v1/debug 404

The source is 192.168.0.12, and all six requests occur within approximately two seconds.

Step 3: Explain each important indicator. GET requests a resource. Status 404 means the requested resource was not found. The paths target administrative portals, login pages, configuration files, and debugging interfaces.

Step 4: Interpret the pattern. An automated client appears to be enumerating sensitive application paths to identify exposed services or files. The Hydra/9.2 User-Agent is an additional clue, although User-Agent strings can be spoofed.

Step 5: Analyst response. Determine whether this was an approved vulnerability scan, inspect other requests from the source, and check whether any sensitive endpoint returned 200 OK.

Instructor takeaway: Numerous requests for unrelated administrative paths in a short period suggest automated reconnaissance. A 404 response is not proof of compromise.

Log 6 — NetFlow v9 Flow Exporter

Ticket: INC-6091 | Correct answer: Traffic Spikes

Step 1: Explain NetFlow. NetFlow summarizes network communications using metadata such as source, destination, protocol, packet count, byte count, and duration.

Step 2: Read the flow.

Src IP: 198.51.100.88

Dst IP: 10.0.1.5

Protocol: 17 (UDP)

Src Port: 53

Dst Port: 53210

Packets Sent: 48,500,000

Bytes Sent: 3,240,000,000

Duration: 45.2 seconds

Step 3: Calculate the volume. Divide 48,500,000 packets by 45.2 seconds. The result is approximately 1.07 million packets per second. The byte count represents about 3.24 GB over the same interval.

Step 4: Interpret the traffic. UDP source port 53 suggests DNS-related responses. A massive volume of DNS-like traffic targeting an internal host could indicate a DNS amplification/reflection DDoS attack.

Step 5: Analyst response. Compare the traffic to baseline, investigate whether requests preceded the responses, and review packet captures and network utilization.

Instructor takeaway: High packet rates over short periods are strong indicators of volumetric traffic spikes. NetFlow alone does not prove DNS amplification.

Log 7 — Palo Alto THREAT Inspection

Ticket: INC-7102 | Correct answer: Activity on Unexpected Ports

Step 1: Identify the source. A Palo Alto threat log provides security inspection information about observed traffic.

Step 2: Examine the fields.

Src_IP: 192.168.100.10

Dst_IP: 192.168.200.5

Dst_Port: 31337

Protocol: udp

App_ID: backdoor-custom

Severity: informational

Step 3: Explain the indicators. Port 31337 has historical associations with backdoor activity. The more important evidence is the application classification backdoor-custom, which suggests the firewall identified suspicious application behavior.

Step 4: Interpret the event. An internal system is communicating across network segments using a high-numbered UDP port and a backdoor-related application signature.

Step 5: Analyst response. Determine the owning process, inspect traffic contents where available, review firewall rules, and verify whether the application classification is accurate.

Instructor takeaway: An unusual port alone does not establish malicious activity. Combine port information with application identification, process evidence, and expected network behavior.

Part 2 — Endpoint and Operating System Logs

Log 8 — Linux ps aux Process Table

Ticket: INC-8812 | Correct answer: Processor Consumption

Step 1: Explain the command. ps aux displays running processes, their owners, resource utilization, process IDs, and command lines.

Step 2: Examine the suspicious process.

USER: nobody

PID: 4912

%CPU: 99.8

%MEM: 1.2

STAT: Rl

COMMAND: /tmp/.ice-unix/xmrig

Step 3: Explain the fields. nobody is a low-privilege account commonly associated with restricted services. PID 4912 identifies the process. %CPU indicates nearly one logical CPU's worth of processing time, while %MEM shows relatively modest memory use. R indicates a running or runnable process; l indicates multithreading.

Step 4: Explain the command. xmrig is cryptocurrency mining software. The complete command includes a stratum+tcp:// mining-pool connection on port 3333 and a wallet identifier. Its execution from a hidden-looking temporary directory is suspicious.

Step 5: Interpret the activity. The server appears to be running a cryptocurrency miner consuming substantial processing resources. Unauthorized mining is commonly called cryptojacking.

Step 6: Analyst response. Verify whether mining is authorized, identify the parent process, investigate how the miner arrived, and examine persistence mechanisms.

Instructor takeaway: High CPU + cryptocurrency mining process + suspicious executable location = potential resource hijacking. ATT&CK T1496.

Log 9 — Linux Kernel OOM-Killer

Ticket: INC-9102 | Correct answer: Memory Consumption

Step 1: Explain the log source. Linux kernel messages report system-level conditions, including memory exhaustion.

Step 2: Identify the key messages.

heap_drain invoked oom-killer

PID: 8812

Comm: heap_drain

Memory cgroup out of memory

Killed process 8812 (heap_drain)

total-vm:16210412kB

anon-rss:15891204kB

Step 3: Explain the terminology. OOM means Out of Memory. total-vm represents total virtual memory size, not necessarily physical RAM. anon-rss indicates anonymous memory resident in RAM, approximately 15.9 GB in this example.

Step 4: Explain what happened. The process heap_drain consumed substantial memory. The kernel's OOM mechanism selected it for termination after a memory cgroup exhausted its available memory.

Step 5: Explain the distinction. Unlike Log 8, which involves excessive processor utilization, this scenario involves memory pressure. It could result from malicious memory exhaustion, a memory leak, or insufficient memory limits.

Step 6: Analyst response. Investigate the process's purpose, memory allocation history, cgroup limits, and whether other applications experienced failures.

Instructor takeaway: oom-killer, large RSS values, and forced process termination point to memory exhaustion. The OOM event itself does not prove malicious intent.

Log 10 — Windows System Event ID 2013

Ticket: INC-1092 | Correct answer: Drive Capacity Consumption

Step 1: Identify the event. The Windows System log reports a storage warning associated with Event ID 2013.

Step 2: Break down the XML.

Provider: Srv

EventID: 2013

Level: 3

Computer: FILESRV01.corp.internal

Param1: C:

Param2: 209715200

Level=3 indicates a warning. Param1 identifies the affected drive.

Step 3: Explain the disk-space value. The lab interprets 209715200 as bytes remaining. That equals 200 MiB, commonly called 200 MB.

Step 4: Explain the impact. A nearly full system drive can interfere with updates, logging, temporary file creation, and application operations.

Step 5: Explain what the log does not show. The scenario attributes the low space to rapid log generation, but the displayed event does not identify which files consumed the storage.

Step 6: Analyst response. Inspect disk utilization, identify the largest directories, review growth trends, and preserve relevant evidence before removing files.

Instructor takeaway: Low disk capacity is an availability concern. Investigate the cause rather than assuming every storage warning is an attack.

Log 11 — Windows AppLocker Event ID 8002

Ticket: INC-1192 | Correct answer: Unauthorized Software

Step 1: Explain AppLocker. AppLocker is a Windows application control feature used to govern which executables, scripts, and other application types may run.

Step 2: Examine the event.

EventID: 8002

Computer: WKST-HR04

PolicyType: EXE

RuleName: Default AppLocker Rule - Block User Profile Executables

FilePath: C:\Users\mbsmith\AppData\Local\Temp\TeamViewer_Desktop.exe

Step 3: Explain the executable. TeamViewer is legitimate remote-access software, but it can violate an organization's application policy or be misused for unauthorized remote access.

Step 4: Explain the path. AppData\Local\Temp is a user-writable temporary directory. Executing remote-administration software from this location deserves investigation.

Step 5: Clarify Event ID 8002. The lab describes this as a blocked or unauthorized execution attempt. However, AppLocker EXE/DLL Event ID 8002 normally indicates that an executable was allowed to run. Event ID 8004 is associated with an executable being blocked.

Step 6: Analyst response. Confirm the effective AppLocker rule and enforcement result, verify whether the software is approved, and review network connections initiated by the executable.

Instructor takeaway: Unauthorized software and malware are not synonymous. Also, know the difference between application execution and application blocking events.

Log 12 — Sysmon Event ID 1: Suspicious Process Execution

Ticket: INC-1204 | Correct answer: Malicious Processes

Step 1: Identify the event. Sysmon Event ID 1 records process creation and can include the executable, command line, account, and parent process.

Step 2: Examine the evidence.

Image: C:\Windows\System32\vssadmin.exe

CommandLine: vssadmin.exe delete shadows /all /quiet

User: NT AUTHORITY\SYSTEM

ParentImage: C:\Users\Public\Downloads\cryptor.exe

ParentCommandLine: cryptor.exe --stage2

Step 3: Explain the command. vssadmin.exe is a legitimate Windows utility for managing Volume Shadow Copy Service information.

- delete shadows requests deletion of shadow copies.
- /all targets all applicable shadow copies.

- /quiet suppresses confirmation prompts.

Step 4: Explain the parent-child relationship. cryptor.exe initiated vssadmin.exe. This is important because ransomware frequently attempts to remove recovery options before encrypting files.

Step 5: Identify the malicious behavior. The process chain strongly suggests ransomware-related recovery inhibition. It does not, by itself, prove that files were subsequently encrypted or that the deletion completed.

Step 6: Analyst response. Isolate the affected endpoint if the incident is active, inspect other processes launched by cryptor.exe, and check backup and shadow-copy status.

Instructor takeaway: Legitimate administrative tools can be used maliciously. The command-line arguments and parent process often provide the strongest evidence. ATT&CK T1490.

Log 13 — Linux Auditd File Modification

Ticket: INC-1390 | Correct answer: Unauthorized Changes

This is one of the more technical logs in the lab, so I would spend additional instructor time explaining it.

Step 1: Explain Auditd. Linux Auditd records security-relevant system activity, including system calls, file access, and process context.

Step 2: Examine the four records.

type=SYSCALL ... syscall=257 success=yes exit=3

ppid=1102 pid=4812 auid=1001 uid=0 gid=0 euid=0

exe="/usr/bin/python3" comm="py_updater" key="hosts_mon"

type=CWD ... cwd="/tmp/.meta"

type=PATH ... item=0 name="/etc/hosts" ...

type=PATH ... item=1 name="/etc/hosts" ...

Step 3: Explain the first record.

- type=SYSCALL: A system call was audited.
- syscall=257: On this x86-64 system, syscall 257 is openat.
- success=yes: The system call succeeded.
- exit=3: The operation returned file descriptor 3.
- pid=4812: The process ID.
- ppid=1102: The parent process ID.
- auid=1001: The original audit login identity.
- uid=0 and euid=0: The process is running with root identity and effective root privileges.
- exe="/usr/bin/python3": The executable is Python.
- comm="py_updater": The recorded process command name.
- key="hosts_mon": An audit rule identifier used to find related events.

Step 4: Explain the second record. type=CWD identifies the working directory, /tmp/.meta. A hidden-looking directory under /tmp is worth investigating, although it is not automatically malicious.

Step 5: Explain the PATH records. Both refer to /etc/hosts, which provides local hostname-to-IP mappings. mode=0100644 describes a regular file with permissions equivalent to 644. ouid=0 and ogid=0 identify root ownership.

Step 6: Explain the security concern. The process successfully opened /etc/hosts with flags consistent with write-capable access. Altering this file could redirect applications to attacker-controlled IP addresses.

Step 7: Clarify the evidence. The openat event proves that the file was opened, but it does not alone prove that new contents were written. To confirm modification, examine write-related activity, file integrity records, and before-and-after contents.

Step 8: Analyst response. Review the current /etc/hosts entries, inspect the Python script, correlate activity with the audit login identity, and determine whether the action was approved.

Instructor takeaway: Auditd requires students to connect multiple record types. SYSCALL explains the action, CWD provides execution context, and PATH identifies the affected file.

Log 16 — Sysmon Process Spawn Hierarchy

Ticket: INC-1612 | Correct answer: Abnormal OS Process Behavior

Step 1: Identify the event. Sysmon Event ID 1 records process creation.

Step 2: Examine the relationship.

Image: C:\Windows\System32\svchost.exe

CommandLine: svchost.exe -k netsvcs -p

User: NT AUTHORITY\SYSTEM

ParentImage: ...\WindowsPowerShell\v1.0\powershell.exe

ParentCommandLine: powershell.exe -ExecutionPolicy Bypass -NoProfile -Enc ...

Step 3: Explain svchost.exe. The Windows Service Host process runs many Windows services. Normally, Windows service instances are created through the Service Control Manager, with services.exe as their parent.

Step 4: Explain the abnormal relationship. Here, PowerShell appears as the parent of svchost.exe, which is unusual for normal service initialization.

Step 5: Explain the PowerShell arguments. -NoProfile avoids loading PowerShell profiles. -ExecutionPolicy Bypass changes execution-policy behavior for the session. -Enc indicates an encoded command.

Step 6: Explain what it suggests. The combination could indicate malicious execution, process masquerading, or another unusual process creation technique. It does not independently establish process injection.

Step 7: Analyst response. Decode the PowerShell command in a safe analysis environment, verify process ancestry, inspect signatures and hashes, and correlate the event with additional endpoint telemetry.

Instructor takeaway: Process trees reveal relationships that individual process names cannot. Pay attention to unusual parent-child combinations.

Log 17 — Sysmon Event ID 11: File Creation

Ticket: INC-1702 | Correct answer: File System Changes or Anomalies

Step 1: Explain the event. Sysmon Event ID 11 records file creation.

Step 2: Read the key fields.

Computer: FS01.corp.internal

RuleName: Ransomware Extension Monitor

Image: C:\Users\Public\cryptor.exe

TargetFilename: D:\Shares\Finance\Q3_Report.pdf.locked

User: CORP\svc-backup

Step 3: Explain the file extension. The .locked extension is suspicious because ransomware often creates encrypted file variants with distinctive extensions.

Step 4: Explain the process context. cryptor.exe is responsible for the file creation event, and the process runs under a backup-related service account.

Step 5: Interpret the behavior. This is consistent with ransomware-related file activity. However, the displayed XML contains only one file creation event; the lab's description of mass file modification would need additional records for confirmation.

Step 6: Analyst response. Search for similar file events, determine whether original files remain accessible, inspect the process, and protect other systems from potential propagation.

Instructor takeaway: A suspicious extension is a clue. Repeated file creation, encryption evidence, and related malicious process activity strengthen a ransomware assessment. ATT&CK T1486.

Log 18 — Sysmon Event ID 13: Registry Persistence

Ticket: INC-1891 | Correct answer: Registry Changes or Anomalies

Step 1: Identify the event. Sysmon Event ID 13 records changes to registry values.

Step 2: Read the relevant fields.

EventType: SetValue

Image: C:\Users\exec\AppData\Local\Temp\updater.exe

TargetObject: HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\PersistenceAgent

Details: C:\Users\exec\AppData\Local\Temp\updater.exe --silent

User: CORP\exec

Step 3: Explain the registry location. HKLM refers to HKEY_LOCAL_MACHINE. The CurrentVersion\Run key can be used to launch programs automatically when users sign in.

Step 4: Explain the change. The process updater.exe set a registry value named PersistenceAgent, pointing back to itself with the --silent argument.

Step 5: Explain persistence. An attacker can use this mechanism to have malicious software start again after a reboot and subsequent logon. Legitimate software also uses Run keys.

Step 6: Analyst response. Verify the executable's legitimacy, check the registry value, identify when it was created, and correlate with other process and network events.

Instructor takeaway: Sysmon Event ID 13 + CurrentVersion\Run + suspicious executable = potential registry-based persistence. ATT&CK T1547.001.

Log 19 — Windows Security Event ID 4698

Ticket: INC-1982 | Correct answer: Unauthorized Scheduled Tasks

Step 1: Explain the event. Windows Security Event ID 4698 indicates that a scheduled task was created.

Step 2: Examine the task information.

SubjectUserName: SYSTEM

TaskName: \Microsoft\Windows\Maintenance\WinUpdateTask

Interval: PT5M

Command: C:\Users\Public\beacon.exe

Step 3: Explain the task name. WinUpdateTask resembles a Windows maintenance task, which could be intended to make it appear legitimate.

Step 4: Explain the trigger. PT5M is an ISO 8601 duration meaning five minutes. The task is configured to repeat at that interval.

Step 5: Explain the action. The scheduled task launches beacon.exe from a public user directory. This is suspicious because an attacker may use scheduled tasks to maintain persistence.

Step 6: Explain the distinction. Although the executable name suggests beaconing, this event proves task creation, not actual network beaconing.

Step 7: Analyst response. Verify task authorization, review the task's creation history and execution events, and inspect the referenced executable.

Instructor takeaway: Event ID 4698 indicates task creation. Look inside the task XML to determine what runs, when it runs, and under which account. ATT&CK T1053.005.

Part 3 — Identity, Access, and Data Exfiltration Logs

Log 14 — Windows Domain Controller Security Log

Ticket: INC-1481 | Correct answer: Unauthorized Privileges

Step 1: Identify the log source. This is a Windows Security event recorded on the domain controller DC01.corp.internal.

Step 2: Examine the event.

EventID: 4672

SubjectUserName: Guest

SubjectDomainName: CORP

PrivilegeList:

SeSecurityPrivilege

SeTakeOwnershipPrivilege

SeLoadDriverPrivilege

SeBackupPrivilege

SeRestorePrivilege

SeDebugPrivilege

SeImpersonatePrivilege

Step 3: Explain Event ID 4672. This event indicates that special privileges were assigned to a new logon session. It does not necessarily mean an administrator permanently changed an account's privileges.

Step 4: Explain the most important privileges.

- SeDebugPrivilege: Allows privileged debugging and access to other processes.
- SeImpersonatePrivilege: Allows a process to impersonate another security context under applicable conditions.
- SeTakeOwnershipPrivilege: Allows taking ownership of securable objects.
- SeBackupPrivilege: Provides special access for backup operations.
- SeRestorePrivilege: Provides special access for restoring files and other objects.
- SeLoadDriverPrivilege: Allows loading or unloading device drivers.

Step 5: Identify the anomaly. The Guest account is normally highly restricted. Seeing a Guest-related logon with powerful privileges is suspicious and requires investigation.

Step 6: Analyst response. Correlate with Event ID 4624, examine the logon type and authentication source, validate the account SID, and investigate whether the privileges were legitimately assigned.

Instructor takeaway: Event ID 4672 + unexpected account + sensitive privileges = potential privilege misuse. It is important to distinguish privileged logon events from permanent privilege assignments.

Log 15 — Suricata EVE JSON Egress Alert

Ticket: INC-1502 | Correct answer: Data Exfiltration

Step 1: Explain Suricata. Suricata is a network intrusion detection and prevention engine. Its EVE JSON output records alerts, network flows, protocol metadata, and other security events.

Step 2: Read the network fields.

event_type: alert

src_ip: 10.0.1.45

src_port: 51204

dest_ip: 198.51.100.1

dest_port: 80

proto: TCP

The internal host is communicating with an external destination over TCP port 80, commonly associated with HTTP.

Step 3: Examine the alert.

action: allowed

signature: ET POLICY Outbound Sensitive Data Archive via Base64 POST

category: Potential Corporate Privacy Violation

severity: 1

Explain that the detection engine identified traffic matching a rule associated with potential sensitive-data transmission.

The allowed action indicates the alert did not block the traffic in this record.

Step 4: Examine the HTTP request.

http_method: POST

url: /upload/stage.php

length: 2147483648

POST is commonly used to submit data to a server. The length field is approximately 2.15 GB if interpreted as a byte count.

Step 5: Explain what is happening. The combination of an outbound POST, a suspicious upload endpoint, and a sensitive-data alert suggests possible data exfiltration.

Step 6: Clarify the evidence. The lab describes a Base64-encoded payload, but the displayed JSON does not include the actual payload. Also, the HTTP length field should be validated before treating it as confirmed transmitted payload size.

Step 7: Analyst response. Investigate the request body or supporting telemetry, verify the number of bytes transferred, determine what information was sent, and check the destination's legitimacy.

Instructor takeaway: Data exfiltration investigations focus on direction, destination, transfer method, volume, and sensitivity of the information. A large HTTP POST alone is not proof of stolen data.

Log 20 — Azure AD Unified Audit Log

Ticket: INC-2091 | Correct answer: Anomalous Access Activity

Step 1: Explain the log source. The lab presents cloud identity authentication events from Azure AD, now called Microsoft Entra ID.

Step 2: Compare the authentication records.

First successful login

10:45:30 UTC

New York, United States

Account: jsmith@corp.com · Windows client · IP: 198.51.100.45

Second successful login

10:49:12 UTC

Tokyo, Japan

Account: jsmith@corp.com · Linux client · IP: 203.0.113.88

Time between logins

3 min 42 sec

Step 3: Explain the timestamps. Both authentication events belong to the same account and occur less than four minutes apart.

Step 4: Explain impossible travel. A person cannot ordinarily travel from New York to Tokyo in three minutes and 42 seconds. This geographic inconsistency is known as an impossible travel indicator.

Step 5: Explain possible causes. Credential compromise is one possibility. Other explanations include VPNs, proxy services, inaccurate IP geolocation, and cloud-based authentication infrastructure.

Step 6: Analyst response. Investigate MFA status, device identity, session information, IP reputation, VPN usage, and whether both logins were expected.

Instructor takeaway: Same account + geographically distant successful logins + unrealistic travel time = anomalous access activity. ATT&CK T1078 may apply when compromised valid credentials are confirmed.

Log 21 — Exchange / Email Gateway MIME Telemetry

Ticket: INC-2190 | Correct answer: Social Engineering / Obfuscated Links

Step 1: Explain the source. Email headers and message contents provide evidence about sender claims, delivery paths, links, and possible phishing attempts.

Step 2: Examine the sender.

From: "Corporate IT Support" <support@paypal-security.com>

The sender claims to be corporate IT support, but the domain contains a capital I that visually resembles a lowercase l.

Step 3: Explain typosquatting and lookalike domains. Attackers register or use deceptive domains resembling legitimate organizations to make messages appear trustworthy.

Step 4: Examine the subject.

URGENT: Mandatory Password Reset Required Immediately

Explain that urgency is a common social engineering tactic. The message attempts to pressure the recipient into acting without verifying the request.

Step 5: Examine the link.

http://login.verify.ru/index.php?cmd=powershell%20-Enc%20SABFAAEAcgBlAG8AdA...

Break down the components:

- http:// indicates an unencrypted HTTP URL.
- login.verify.ru is the destination hostname.
- /index.php identifies the requested server-side resource.
- ?cmd= introduces a query parameter.
- %20 is URL encoding for a space.
- powershell -Enc resembles a PowerShell encoded-command invocation.
- The following text resembles Base64-encoded data.

Step 6: Explain what is suspicious. The message combines a deceptive sender, urgent password-reset language, and an obfuscated link containing command-like text.

Step 7: Clarify the evidence. The presence of PowerShell text inside a URL does not mean PowerShell executed on the recipient's computer. Execution would require additional behavior or evidence.

Step 8: Analyst response. Analyze the URL in a safe environment, inspect authentication results such as SPF, DKIM, and DMARC, search for similar messages, and determine whether anyone clicked the link or submitted credentials.

Instructor takeaway: Phishing detection requires analyzing the sender, message content, destination URL, and psychological tactics together. ATT&CK T1566.002.

Part 4 — Instructor Wrap-Up and Classroom Delivery

After completing the 21 scenarios, reinforce the distinction between the log source, the observable evidence, and the analyst's conclusion.

Key event IDs students should recognize

Event ID	Log source	What it records
1	Sysmon	Process creation
3	Sysmon	Network connection
11	Sysmon	File creation
13	Sysmon	Registry value modification
4672	Windows Security	Special privileges assigned to a new logon
4698	Windows Security	Scheduled task created
2013	Windows System / Srv	Disk-space warning
8002	AppLocker EXE/DLL	Executable allowed
8004	AppLocker EXE/DLL	Executable blocked